Vulnerability Assessment Report

Subject: Legacy Infrastructure Server Vulnerability Assessment
Target Host: 192.168.56.109
Assessor: Mitchelle Anduru
Role: Junior Cybersecurity Analyst
Assessment Date: 03 March 2026

1. Executive Summary

This vulnerability assessment was conducted against a legacy server representing a smart-city infrastructure environment, with the objective of identifying exposed services, validating high-risk weaknesses, and assessing the broader security impact of the host if deployed in a real municipal operations setting. The target system, a Metasploitable 2 instance, presented a significantly weakened security posture characterized by an unusually large attack surface, numerous outdated services, multiple insecure remote administration protocols, exposed database services, and a critical shell service indicative of severe compromise risk.

Reconnaissance and service enumeration were performed from a Kali Linux virtual machine using Nmap, followed by controlled manual validation of selected findings. Nessus Essentials was successfully installed; however, plugin updates could not complete because of insufficient disk space on the assessment VM. As a result, the most reliable findings in this report are based on Nmap evidence and analyst validation rather than a completed plugin-driven scan. The Nmap evidence snapshot shown in the appendix image on page 13 clearly supports the reported exposure of FTP, SSH, Telnet, SMB, r-services, a bindshell on port 1524, MySQL, PostgreSQL, VNC, IRC, and web services.

From a business-risk perspective, a host configured in this manner would be considered unsafe for any production or public-sector environment. In a real smart-city deployment, successful exploitation could enable unauthorized access to operational platforms, disruption of municipal services, compromise of backend data stores, and lateral movement into interconnected administrative or infrastructure systems.

2. Assessment Scope and Objectives

The assessment was performed in an authorized lab environment and focused on evaluating the security posture of a legacy infrastructure server simulating services such as traffic monitoring and smart streetlight management. The review was aligned to CIS Controls v8.1 and aimed to identify vulnerabilities, insecure services, control weaknesses, and remediation priorities relevant to a critical operations context.

System assessed
Legacy smart-city infrastructure server simulation (Metasploitable 2)

Target IP
192.168.56.109

Tools used

- Kali Linux
- Nmap

- Nessus Essentials
- Manual service validation via terminal-based testing

Assessment objectives

- identify exposed and vulnerable services
- assess the likelihood and impact of exploitation
- evaluate security controls and architectural weaknesses
- recommend remediation actions aligned with CIS Controls

3. Methodology

The assessment followed a practical vulnerability review workflow:

1. Conducted host discovery and service enumeration using Nmap.
2. Reviewed banners, ports, and service types to identify legacy or insecure technologies.
3. Performed limited manual verification to confirm that selected high-risk services were genuinely reachable.
4. Assessed the overall attack surface and business impact in the context of a smart-city operations environment.
5. Mapped remediation priorities to CIS Controls v8.1.

The assessment was intentionally non-destructive. Validation focused on confirming risk exposure rather than exploiting the host beyond the lab requirements. A limitation of the exercise was that Nessus plugin updates could not complete due to disk-space constraints, reducing automated enrichment but not invalidating the major findings already confirmed through enumeration and manual checks.

4. Asset Identification and Exposure Overview

Initial reconnaissance showed that the host exposed a broad range of services that would normally be heavily restricted, segmented, or completely disabled in production. The concentration of administrative services, file-sharing protocols, databases, legacy remote access services, and public-facing web components on a single host materially increased the attack surface.

Key identified services included:

- FTP on port 21 (vsftpd 2.3.4)
- SSH on port 22 (OpenSSH 4.7p1)
- Telnet on port 23
- SMTP on port 25 (Postfix)
- DNS on port 53 (BIND 9.4.2)
- HTTP on port 80 (Apache 2.2.8)
- RPC on port 111

- SMB/NetBIOS on ports 139 and 445 (Samba 3.X–4.X)
- legacy remote shell services on ports 512, 513, and 514
- Java RMI on port 1099
- a bindshell on port 1524
- NFS on port 2049
- secondary FTP on port 2121 (ProFTPD 1.3.1)
- MySQL on port 3306
- PostgreSQL on port 5432
- VNC on port 5900
- IRC on port 6667 (UnrealIRCd)
- an additional unknown HTTP-like service on port 8180

This breadth of exposure is itself a major security concern. Even before vulnerability-specific analysis, the host demonstrated poor service minimization and weak architectural separation.

5. Security Controls and Configuration Review

The assessment found little evidence of effective hardening or modern control implementation. Multiple remote administration paths were exposed simultaneously, including SSH, Telnet, VNC, rexec, rlogin, and rsh, which conflicts directly with least privilege and secure access design principles. Encryption controls were also clearly inadequate because Telnet and r-services transmit credentials and session data insecurely, and VNC may expose sensitive interactive access if not properly protected.

Additional weaknesses included:

- poor service minimization, with duplicate FTP services and multiple databases exposed
- outdated software versions far outside normal secure maintenance standards
- absence of effective segmentation between management, application, and data services
- no visible evidence of MFA, centralized identity, or role-based access control
- weak authentication hygiene, including default local credentials (msfadmin / msfadmin) used for console access during validation

In a real operational environment, this combination of control failures would make the host highly susceptible to unauthorized access and difficult to defend once targeted.

6. Threat Modeling and Risk Assessment

Threat modeling was performed based on ease of attacker access, exploitability, service criticality, and likely operational consequences. In a smart-city context, successful compromise could affect monitoring systems, backend control logic, data integrity, and service availability.

Priority Findings

Finding 1: Exposed Bindshell on Port 1524

Risk Level: Critical

A service identified as a Metasploitable root shell was exposed on port 1524. This is the most severe observation in the assessment because it suggests a direct shell-level access path that could lead to immediate system compromise.

Business impact
An attacker who gained access through this path could obtain direct command execution, disrupt services, alter data, and use the server as a pivot point to attack adjacent systems.

Recommendation
Immediately disable the service, isolate the host, investigate for persistence or compromise indicators, and rebuild the system from a known-good baseline if this were a real-world asset.

Finding 2: Telnet Exposed on Port 23

Risk Level: High

Telnet was reachable externally. Because Telnet transmits credentials and session traffic in plaintext, it creates a high risk of credential interception and unauthorized administrative access.

Business impact
In a municipal network, interception of remote administrative credentials could enable unauthorized system control and facilitate movement into more sensitive environments.

Recommendation
Remove Telnet entirely and replace it with hardened SSH only.

Finding 3: Legacy r-services Exposed on Ports 512, 513, and 514

Risk Level: High

The host exposed rexec, rlogin, and rsh services. These protocols are inherently insecure and are incompatible with modern secure administration standards.

Business impact
Their presence creates multiple low-trust remote access pathways that attackers can abuse for unauthorized access or credential compromise.

Recommendation
Disable all r-services immediately and verify they are not reintroduced through legacy packages or startup services.

Finding 4: Outdated FTP Services Exposed

Risk Level: High

Two FTP services were identified, including vsftpd 2.3.4 and ProFTPD 1.3.1. This not only increases the attack surface but also raises concern due to the age and historic security issues associated with legacy FTP deployments.

Business impact
FTP services increase exposure to weak authentication, insecure file transfer, and potential remote exploitation paths depending on configuration and version-specific flaws.

Recommendation
Remove non-essential FTP services and replace any required file transfer workflows with secure alternatives such as SFTP.

Finding 5: SMB/NetBIOS Exposure on Ports 139 and 445

Risk Level: High

Samba services were externally visible on ports 139 and 445. These services are commonly abused for enumeration, unauthorized file access, and lateral movement.

Business impact
A compromised or weakly configured SMB service can expose internal file shares and facilitate propagation within a broader network.

Recommendation
Restrict SMB to trusted internal hosts only, harden file-sharing permissions, and disable unnecessary SMB exposure at the network boundary.

Finding 6: Network-Reachable Databases on Ports 3306 and 5432

Risk Level: High

MySQL and PostgreSQL services were reachable over the network. Direct exposure of database platforms materially increases the risk of brute-force attempts, misconfiguration abuse, data theft, and service disruption.

Business impact
In a real smart-city deployment, compromise of backend databases could expose operational, administrative, or citizen-related data and undermine the integrity of city services.

Recommendation
Restrict database access to approved internal application hosts only and place databases behind internal segmentation controls.

Finding 7: Outdated Web and DNS Stack

Risk Level: Medium

Apache 2.2.8 and BIND 9.4.2 were identified. Both are legacy software versions that raise concerns regarding unsupported code, historical weaknesses, and configuration drift.

Business impact
Compromise of web or DNS infrastructure could enable information leakage, service disruption, and attacker footholds that support broader intrusion objectives.

Recommendation
Upgrade or replace these components and harden them according to modern baseline standards.

Finding 8: VNC Exposure on Port 5900

Risk Level: Medium

A VNC service was reachable on port 5900. Depending on its configuration, this could expose remote desktop access with weak or absent authentication protections.

Business impact
Improperly secured remote desktop services can permit unauthorized interactive access and increase the likelihood of compromise.

Recommendation
Disable VNC if not required, or strictly limit access to trusted management networks with strong authentication controls.

7. Security Posture Validation

Manual validation confirmed that the reported exposure was genuine and not an artifact of false-positive scanning. Connectivity to the host was verified from Kali, and additional testing confirmed that critical services including FTP, SSH, Telnet, SMTP, HTTP, SMB, databases, VNC, and remote shell services were externally reachable. Netcat and Nmap testing also validated the presence of high-risk remote access ports. The bindshell on port 1524 was particularly significant because it was identified as a root shell service consistent with critical compromise exposure.

The evidence screenshot on page 13 reinforces these findings by visually showing the Nmap service results and the breadth of open ports and service banners detected during the assessment.

8. Monitoring, Logging, and Incident Response Readiness

The assessment found no clear evidence of robust monitoring, centralized logging, or incident response readiness. No SIEM, host-based monitoring, or centralized log forwarding solution was identified. There was also no visible evidence of alerting for failed logins, suspicious SMB usage, unusual shell access, or database abuse. Log retention and integrity protections were not observed, meaning that even if compromise occurred, attackers could potentially remove or alter evidence.

This is a major operational weakness. A vulnerable host is always a concern, but a vulnerable host with poor detection capability presents a much greater business risk because compromise may go unnoticed until service disruption or data loss becomes visible.

9. Recommendations and Hardening Priorities

The following remediation priorities should be treated as urgent:

Immediate Priorities

- Disable the bindshell on port 1524 and isolate the system for investigation.

- Remove Telnet, rexec, rlogin, rsh, and any other insecure plaintext or legacy remote access services.
- Disable duplicate and unnecessary services, including redundant FTP, IRC, unused RPC components, and non-essential VNC access.
- Remove default or shared credentials and enforce strong authentication controls.

High-Priority Improvements

- Upgrade or replace outdated software, including Apache, BIND, Samba, FTP services, and database engines.
- Harden SSH by disabling root login, enforcing key-based authentication, and limiting source networks.
- Restrict SMB, NFS, MySQL, and PostgreSQL access to trusted internal hosts only through firewall policy and segmentation.
- Introduce role-based access control and least privilege for administrative functions.

Monitoring and Resilience Improvements

- Implement centralized logging and alerting for authentication failures, service changes, file-sharing activity, and privileged access events.
- Adopt routine vulnerability management with sufficient scanner capacity, patch validation, and post-remediation rescanning.
- Separate smart-city operational networks from user, web, and database zones to reduce blast radius and lateral movement risk.

CIS Controls Alignment

The report's original recommendations appropriately align to CIS Controls, particularly:

- **CIS Control 4** for secure configuration and service minimization
- **CIS Control 5 and 6** for account management and access control
- **CIS Control 7** for vulnerability management
- **CIS Control 8** for audit log management
- **CIS Control 12 and 13** for network infrastructure management and network monitoring/defense

10. Conclusion

The assessed host should be considered **high risk** and operationally unsafe in its current state. It exposes too many services, relies on outdated and insecure technologies, lacks evidence of meaningful hardening and segmentation, and includes at least one critical shell service that represents a severe compromise pathway. These weaknesses are not isolated misconfigurations; they reflect a fundamentally poor security posture.

The most significant findings were the exposed bindshell, the continued presence of Telnet and legacy r-services, the broad exposure of SMB and databases, and the absence of meaningful

monitoring and incident response capability. In a real smart-city context, these weaknesses could lead to unauthorized access, service disruption, data compromise, and lateral movement into other municipal systems.

The next steps should be immediate service reduction, hardening, segmentation, credential cleanup, and a repeat assessment after remediation. Once scanner storage constraints are resolved, the environment should be rescanned using both credentialed and non-credentialed methods to validate closure of the identified risks.